

Pashov Audit Group
Security Review: Sample Vault
Date: 2024-10-12

Executive Summary

This is a synthetic Pashov-style audit report used for testing.

Findings

[H-1] Reentrancy in withdraw allows fund theft

Description

The withdraw function in target/contracts/Vault.sol:L42-L60 calls an external token before updating internal accounting state. An attacker can re-enter withdraw and drain the vault.

Proof of Concept

Alice deposits 100 tokens. Alice deploys a malicious token whose transfer hook calls back into withdraw before the balance update in target/contracts/Vault.sol:L55. The re-entry drains the vault.

Recommendation

Apply the checks-effects-interactions pattern: update internal balances before the external token call. Consider adding a non-reentrancy modifier to the withdraw function.

[M-2] Integer overflow in fee calculation results in loss

Description

The fee calculation in target/contracts/Fee.sol:L100 multiplies two unchecked uint256 values which can overflow for large inputs.

Recommendation

Use Solidity 0.8+ checked arithmetic or SafeMath for the fee calculation. Add unit tests covering the boundary cases.